

برنامج الدبلوم العالي في حوكمة الأمن السيبراني

المحاضرة الرابعة : معيار ISO 27014 و ISO 27001

إعداد : أ.د. ضياء جاسم كاظم

المدخل المفاهيمي

العلاقة بين الحوكمة والإدارة

فهم الفارق الجوهرى والتكامل الوظيفى بين التوجيه الاستراتيجى والتطبيق الفنى والعمليات.

معييار ISO/IEC 27001: نظام إدارة أمن المعلومات



ما هو معيار ISO/IEC 27001؟

يعد المعيار الدولي الأبرز المخصص لتأسيس، تطبيق، تشغيل، ومراجعة نظام إدارة أمن المعلومات ISMS-Information Security Managmeent System. ويركز المعيار على إدارة المخاطر السيبرانية وحماية أصول المعلومات. ✓

✓ يعتمد على دورة التخطيط والتنفيذ والمفاهيم الإدارية المستمرة Plan-Do-Check-Act -(PDCA).

✓ يحدد المتطلبات الإدارية والتقنية القابلة للتدقيق والمنح الشهادي.

✓ يضمن استمرارية الأعمال وحماية سرية وسلامة وتوافر البيانات.

معييار ISO/IEC 27014 حوكمة الأمان

إطار حوكمة أمن المعلومات للمؤسسات

يركز معيار **ISO/IEC 27014** على الدور الاستراتيجي لمجلس الإدارة والإدارة العليا في قيادة الأمن السيبراني.

يقدم إرشادات شاملة لكيفية تقييم، توجيه، ومراقبة أنشطة أمن المعلومات لضمان توافقها التام مع الأهداف الاستراتيجية للمؤسسة وتحقيق القيمة المضافة.

ISO/IEC 27014:2020
Governance of Information Security

support@pacificcert.com  www.pacificcert.com

التكامل والفرق الأساسي بين المعيارين

معيار ISO/IEC 27001 (الإدارة)

المستوى: إدارة تكنولوجيا المعلومات والأمن السبراني التشغيلية.

التركيز: تصميم الضوابط الأمنية، إدارة المخاطر اليومية، وتطبيق السياسات.

السؤال الجوهرى: هل نطبق العمليات الأمنية والضوابط بشكل صحيح وفعال؟

معيار ISO/IEC 27014 (الحوكمة)

المستوى: مجلس الإدارة والإدارة التنفيذية العليا.

التركيز: الرؤية الاستراتيجية، المبادئ، المساءلة، وتوجيه الاستثمارات الأمنية.

السؤال الجوهرى: هل نقتني ونتوجه نحو الاتجاه الصحيح الذي يحمي المؤسسة ويكفل نموها؟

المبادئ الأساسية لحوكمة الأمن (ISO 27014)



المساءلة والامتثال

تحديد المسؤوليات والالتزام بالقوانين والتشريعات الوطنية والدولية.



توليد القيمة

تحقيق عائد استثماري آمن يعزز كفاءة المؤسسة وثقة العملاء.



المحاذاة الاستراتيجية

ربط استراتيجية الأمن السيبراني بأهداف العمل المؤسسي المباشرة.

تأثير الحوكمة على تقليل المخاطر السيبرانية

تثبت الدراسات والأبحاث الأكاديمية أن المؤسسات التي تدمج معيار ISO 27014 مع ISO 27001 تحقق انخفاضاً جوهرياً في الثغرات الحرجية ونسبة نجاح الحوادث السيبرانية.

تضمن الحوكمة الرشيدة توفير التمويل والموارد الكافية لفرق الأمن التشغيلية للقيام بمهامها بفاعلية.

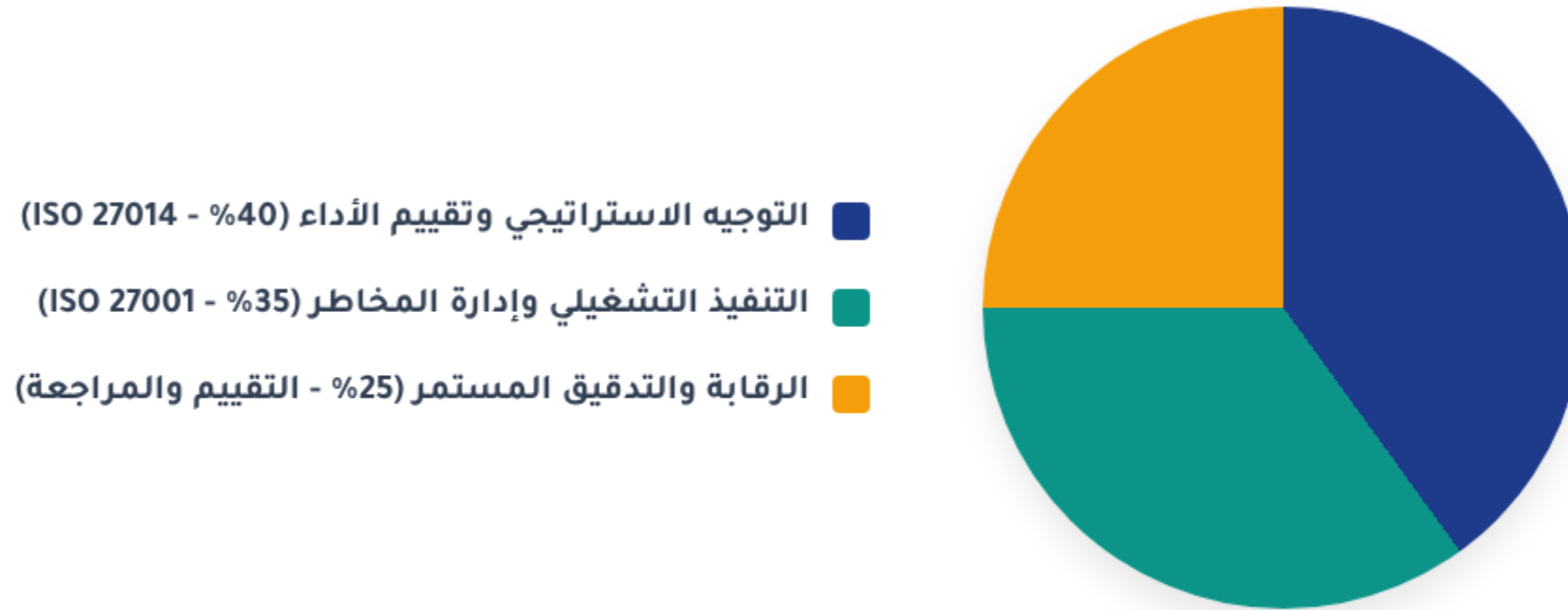
100%

التزام الإدارة العليا بالمساءلة

ISO 27014 و ISO 27001 مقارنة تفصيلية بين

وجه المقارنة	معيار ISO/IEC 27001	معيار ISO/IEC 27014
طبيعة المعيار	معيار متطلبات قابل للتدقيق والمنح الشهادي (Certification).	معيار إرشادي للحوكمة (Guidance Standard).
الجمهور المستهدف	مدراء الأمن السيبراني (CISO) والفرق الفنية والإدارية.	مجلس الإدارة (Board of Directors) والإدارة العليا.
العمليات الأساسية	تقييم المخاطر، معالجة المخاطر، والتحسين المستمر.	التقييم (Evaluate)، التوجيه (Direct)، والمراقبة (Monitor).
الهدف الرئيسي	بناء وتنفيذ ضوابط أمنية تشغيلية لحماية البيانات.	كفالة التوجيه الاستراتيجي والمساءلة المؤسسية.

توزيع أدوار الحوكمة والإدارة



يوضح الشكل مدى تكامل أنشطة الحوكمة والإدارة والتدقيق لبناء منظومة أمنية متماسكة ومستدامة

مراحل تطبيق إطار الحوكمة والـ ISMS

2. التخطيط والتصميم

بناء سياسات ISO 27001 وتقييم
المخاطر الأولوية.

3. التطبيق والتشغيل

تنفيذ الضوابط الأمنية وتدريب الكوادر
البشرية.

1. التقييم والتوجيه

تحديد التوجه الاستراتيجي وسياق
المؤسسة وفق ISO 27014.

4. المراقبة والتحسين

إجراء التدقيق الداخلي ورفع التقارير
لمجلس الإدارة.

الخلاصة الاستراتيجية للطلبة

إن النجاح في حوكمة الأمن السيبراني يتطلب خلق جسر متين بين القرارات الصادرة من غرفة مجلس الإدارة (ISO 27014) والتطبيقات الميدانية التي ينفذها مهندسو ومدراء الأمن السيبراني (ISO 27001) بدون هذا التكامل، تبقى الحوكمة مجرد شعارات، ويبقى الأمن التشغيلي معزولاً عن اهتمامات المؤسسة.

باب الأسئلة والمناقشة

طلبتنا الأعضاء :كيف يمكن لمجلس الإدارة قياس كفاءة تطبيق ISO 27001 عملياً؟
